

Cryptography and Network Security Chapter 16

- Fifth Edition
by William Stallings
- Lecture slides by
Lawrie Brown



Transport-Level Security

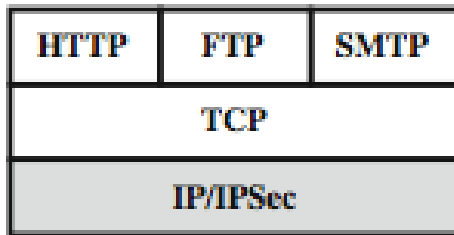
Arabic Language Audio Comments by
Prof. Mohamed Ashraf Madkour

Web Security

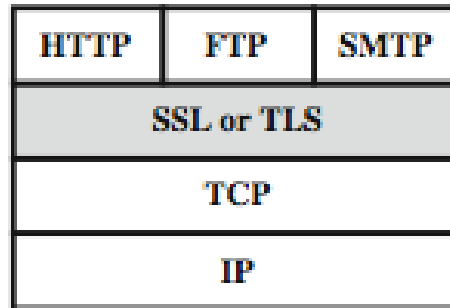


- Web now widely used by business, government, individuals
- but Internet & Web are vulnerable
- have a variety of threats
 - integrity
 - confidentiality
 - denial of service
 - authentication
- need added security mechanisms

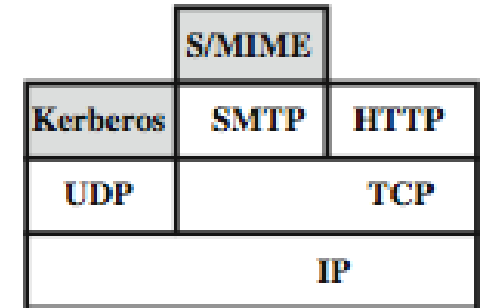
Web Traffic Security Approaches



(a) Network Level



(b) Transport Level



(c) Application Level

Several approaches to providing Web security are possible. The various approaches that have been considered are similar in the services they provide and, to some extent, in the mechanisms that they use, but they differ with respect to their scope of applicability and their relative location within the TCP/IP protocol stack.

- a) In the given HTTPS protocol architecture, give the protocol names corresponding to the shown numbers (from 1 to 6)
- b) What is the importance of the HELLO messages in the SSL protocol?
- c) What are the two security services that the SSL protocol provides to HTTPS?

1	2	3	4
5			
6			
IP Protocol			

Phase 1

Establish security capabilities, including protocol version, session ID, cipher suite, compression method, and initial random numbers.

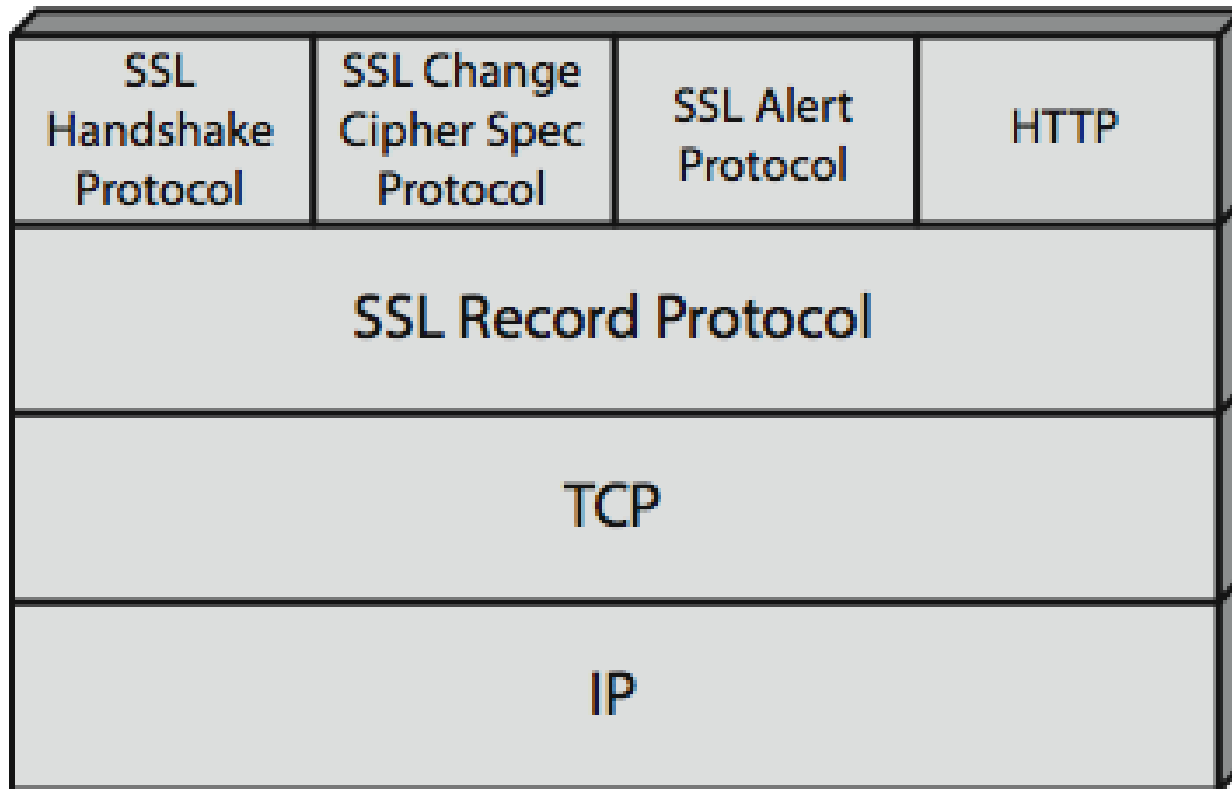
- **Confidentiality**
- **message integrity**

SSL (Secure Socket Layer)



- transport layer security service
- originally developed by Netscape
- version 3 designed with public input
- subsequently became Internet standard known as TLS (Transport Layer Security)
- uses TCP to provide a reliable end-to-end service
- SSL has two layers of protocols

SSL Architecture



Two Important SSL Concepts



➤ **SSL connection**

- a transient, peer-to-peer, communications link
- associated with one SSL session



➤ **SSL session**

- an association between client & server
- created by the Handshake Protocol
- define a set of cryptographic parameters
- may be shared by multiple SSL connections

SSL Record Protocol Services



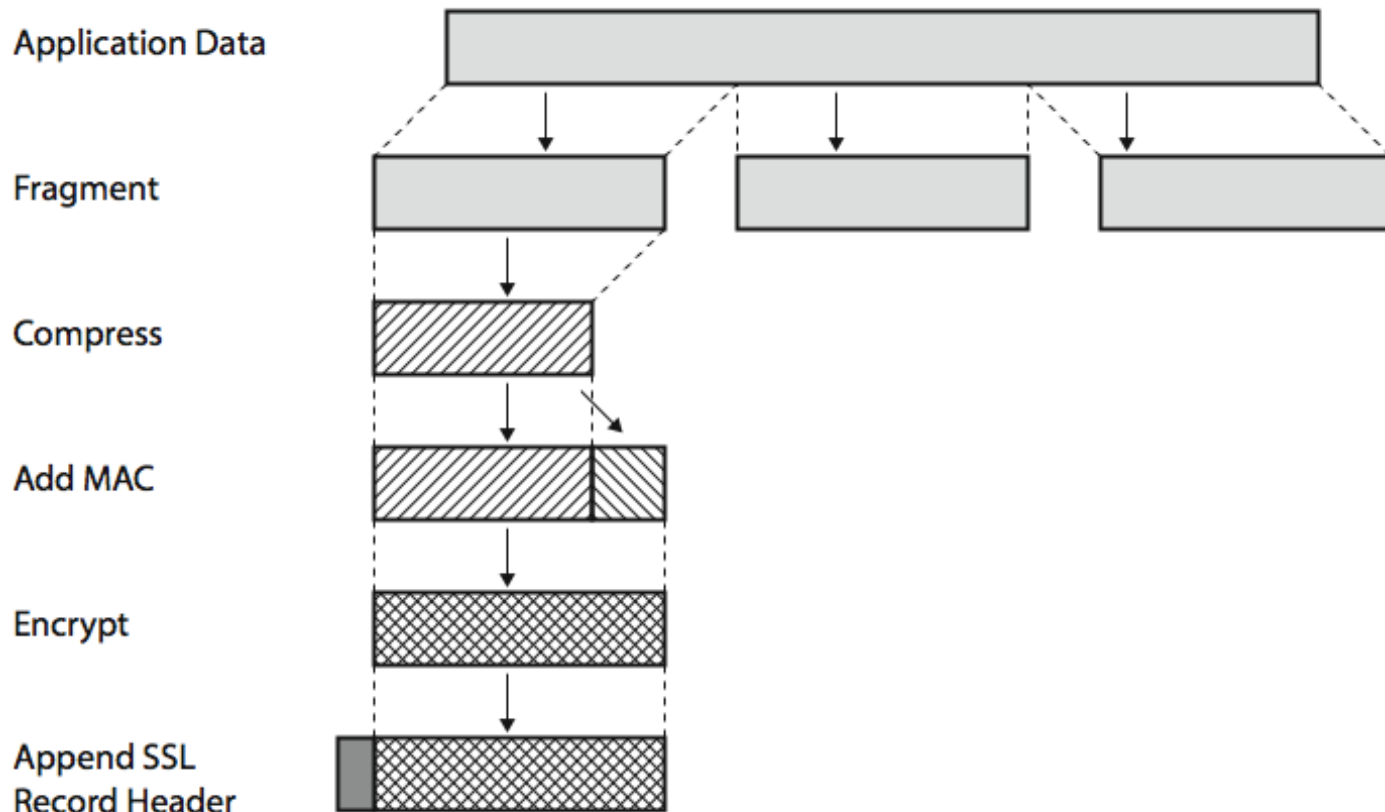
➤ **confidentiality**

- using symmetric encryption with a shared secret key defined by Handshake Protocol
- can use several encryption ciphers such as: AES, IDEA, RC2-40, DES-40, DES, 3DES, Fortezza, RC4-40, RC4-128
- message is compressed before encryption

➤ **message integrity**

- using a MAC with shared secret key
- like HMAC but with different padding

SSL Record Protocol Operation



SSL Change Cipher Spec Protocol



- one of 3 SSL specific protocols which use the SSL Record protocol
- a single message
- causes pending state to become current
- hence updating the cipher suite in use

1 byte

1

(a) Change Cipher Spec Protocol

SSL Alert Protocol



- conveys SSL-related alerts to peer entity
- severity
 - warning or fatal
- specific alert
 - fatal: unexpected message, bad record mac, decompression failure, handshake failure, illegal parameter
 - warning: close notify, no certificate, bad certificate, unsupported certificate, certificate revoked, certificate expired, certificate unknown
- compressed & encrypted like all SSL data

1 byte 1 byte

Level	Alert
-------	-------

(b) Alert Protocol

SSL Handshake Protocol



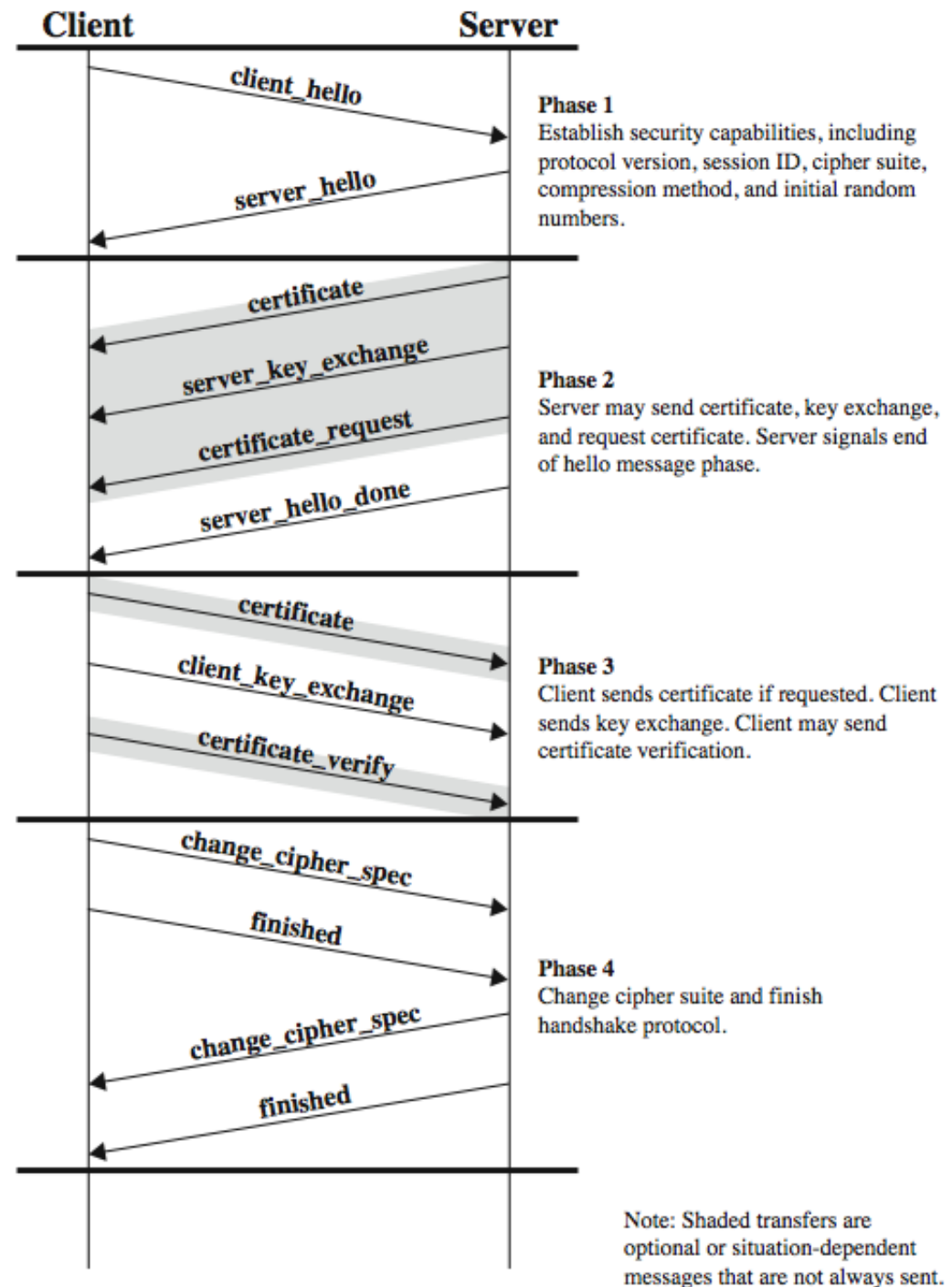
- allows server & client to:
 - authenticate each other
 - to negotiate encryption & MAC algorithms
 - to negotiate cryptographic keys to be used
- comprises a series of messages in four phases
 1. Establish Security Capabilities
 2. Server Authentication and Key Exchange
 3. Client Authentication and Key Exchange
 4. Finish

1 byte	3 bytes	≥ 0 bytes
Type	Length	Content

SSL Handshake Protocol



Time



Cryptographic Computations



- master secret creation
 - a one-time 48-byte value
 - generated using secure key exchange (RSA / Diffie-Hellman) and then hashing information.
- generation of cryptographic parameters (6 secret values as follows)
 - client write MAC secret, a server write MAC secret, a client write key, a server write key, a client write IV, and a server write IV
 - these 6 secrets are generated by hashing the master secret using a simple algorithm and a hash function.

TLS (Transport Layer Security)



- IETF standard RFC 2246 like SSLv3
- with minor differences
 - in record format version number
 - uses HMAC for MAC
 - a pseudo-random function expands secrets
 - based on HMAC using SHA-1 or MD5
 - has additional alert codes
 - some changes in supported ciphers
 - changes in certificate types & negotiations
 - changes in cryptographic computations & padding

HTTPS



HTTPS (HTTP over SSL)

- combination of HTTP & SSL/TLS to secure communications between browser & server
 - documented in RFC2818
 - no fundamental change using either SSL or TLS

use `https://` URL rather than `http://`

- and port `443` rather than `80`

encrypts

- URL, document contents, form data, cookies, HTTP headers

HTTPS Use



- For HTTPS, the agent acting as the HTTP client also acts as the TLS client.
- connection initiation
 - TLS handshake then HTTP request(s)
- connection closure
 - have “Connection: close” in HTTP record
 - TLS level exchange close_notify alerts
 - can then close TCP connection
 - must handle TCP close before alert exchange sent or completed

Summary

- Have considered:
 - Web security
 - TLS / SSL protocol
 - HTTPS